Efficient Clustering of Software Vulnerabilities using Self Organizing Map (SOM)

Khyati Panchal*, Siddhartha Shankar Das†, Luis De La Torre*, John Miller*,
Robert Rallo‡, Mahantesh Halappanavar‡
*Washington State University, †Purdue University, ‡Pacific Northwest National Lab.
*{khyati.panchal, luis.delatorre, jmiller16}@wsu.edu, †das90@purdue.edu,
‡{hala, robert.rallo}@pnnl.gov

2022 IEEE International Symposium on Technologies for Homeland Security (HST) | 978-1-6654-9404-5/22/$31.00 ©2022 IEEE | DOI: 10.1109/HST56032.2022.10025443

***Abstract*—The common vulnerabilities and exposures (CVE) database was created with a mission to "identify, define, and catalog publicly disclosed cybersecurity vulnerabilities". This rich body of information can be used to enable rapid and efficient response to secure and defend cyber operations and protect critical cyber infrastructure. The main goal of this paper is to develop a visual analytic tool to enable deep analysis of CVEs using unsupervised clustering techniques. We enhance our analysis by first mapping CVEs to hierarchical-classes in Common Weakness Enumeration (CWE) using information in the National Vulnerability Database (NVD). Both the mapping and the numerical representation of CVEs are enabled by V2W-BERT, which uses natural language processing of the extensive information in NVD to generate a large tabular database of 137,226 CVE entries from 1999 to 2020, where each CVE is represented by a vector of 768 numerical features. The vectorized data is processed by Self-Organizing Maps (SOM), which is an unsupervised machine learning technique for dimensionality reduction, visual representation and clustering.**

Using a Torus map of 6417 units, we achieve 10-fold data compression of 140k CVEs using SOM. The trained map is further clustered using standard K-means clustering into 138 clusters of CVEs. We conducted a brief investigation of the rich mapping of CVEs to best-matching-units to K-means clusters, as well as CVEs to CWEs. For example, this novel mapping provided insight into the role of CWE-59 and CWE-264 in several CVEs that is otherwise hard to explore in the original data. We conclude that our this novel approach will not only enable deep analysis of the complex relationships between CVEs and CWEs, but also a mechanism to quickly respond to and design mitigation actions for rapidly evolving vulnerabilities that have not been mapped to existing CWEs.

I. Introduction

Generally, attacks are detected from software applications while exploiting vulnerabilities or weaknesses and leading us to major problems. A software vulnerability is a flaw in the design or implementation of a product that enables an attacker to exploit the security measures implemented by defenders [1]. National Vulnerability Database (NVD) is a public data repository for maintaining standardized information on software vulnerabilities and configuration settings that affect software applications. The purpose of NVD is to provide valuable information to help organizations with future mitigation processes and understand trends and patterns of software vulnerabilities. To allow this information for public usage so that programmers can identify and resolve vulnerabilities, the co-creators of MITRE Corporation came up with the Common Enumeration of Vulnerabilities (CVE) list also known as dictionary of publicly available vulnerabilities and exposures in 1999. The purpose of CVE is to effortless share data across different vulnerability capabilities (tools, repositories,and services).

Another important community-developed list from MITRE is Common Weakness Enumeration (CWE)[1]. While vulenrabilities are specific to products and protocols, weaknesses are general (abstract) definitions. CWE provides a list of common software and hardware weaknesses that can be exploited by cyber attackers. CWE is a hierarchically designed dictionary of software weaknesses that allows understanding software flaws, potential impact of their exploitation, and design techniques to mitigate these flaws. Classification of CVE instances to CWEs allows us to help develop countermeasure techniques and get a better understanding of CVE

[1]http://cwe.mitre.org/

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.

implications because of hierarchical structure of CWEs. Based on the CVE and CWE mapping we can associate impact of specific vulnerability to weakness and develop steps to mitigate them. Also, by analyzing the correct path from a root to lower level nodes provides valuable insight and functional directions to learn more about specific weakness. In this work, we consider all the CVE's from 1999 to 2020, where each CVE is mapped to related CWE's using a hierarchical supervised multi-class classification tool V2W-BERT, which will be described soon.

Self-Organizing Maps (SOM) is a data visualization paradigm introduced by Professor Teuvo Kohonen. SOM clusters similar data and performs data mining using topology-preserving mapping and training through data distribution to achieve data compression. SOM provides visualization of the structure of higher-dimensional data space in lower dimensions by allowing neighborhood relations on a rectangular or hexagonal lattice [2]. It gives dimensionality reduction which allows to visualize and interpret what would otherwise be, indecipherable data. SOMs generate subspaces with an unsupervised learning neural network trained with a competitive learning algorithm. For clustering, neuron weights are fine-tuned based on their closeness to "winning" neurons (i.e. neurons that most closely resemble a sample input). When we train input data sets on multiple iterations as an outcome, we achieve the association of similar neurons and vice versa. A SOM consists of neurons, which are connected to adjacent neurons by neighborhood relations. In the training step, one vector x from the input set is chosen, and all the weight vectors of the SOM are calculated using some distance measure such as the Euclidean distance (Kohonen, 2001). The neuron, whose weight vector is closest to the input x is called the best-matching unit (BMU). After finding the BMU, the weighting vectors of the SOM are adjusted so that the BMU is moved closer to the input vector.

Automated mapping (classification) of existing and newly discovered vulnerabilities (CVEs) to hierarchically structured weakness enumerations (CWEs) enables understanding and mitigation of vulnerabilities. However, automation is plagued with several challenges, such as semantic differences in the structure of CVEs and CWEs, overlapped hierarchy of CWE classes, and insufficient training data where rare CWE classes have few or zero CVEs mapped to them. Recently, Das et al. [3] developed a novel Transformer-based framework, V2W-BERT, to address this problem and demonstrated classification of vulnerabilities with high accuracy. V2W-BERT brings together Transformer-based language models [4] and link prediction framework using the Siamese model [5] to embed semantically different text forms in CVEs and CWEs into the same semantic space. In this paper, we use V2W-BERT for two purposes: (i) NLP-based embeddings for each CVE in the form a vector of 768 numerical values, and (ii) CVE-to-CWE mapping for CVEs from 1999 to 2020.

A. Contributions

The main contribution of this work is clustering of over 100k software vulnerabilities using self-organizing maps (SOM). The enriched dataset from CVE clustered together with CWE mapping will enable an unprecedented insight into vulnerabilities and weaknesses, and holds the promise to enable cyber defenders to respond to novel vulnerabilities.

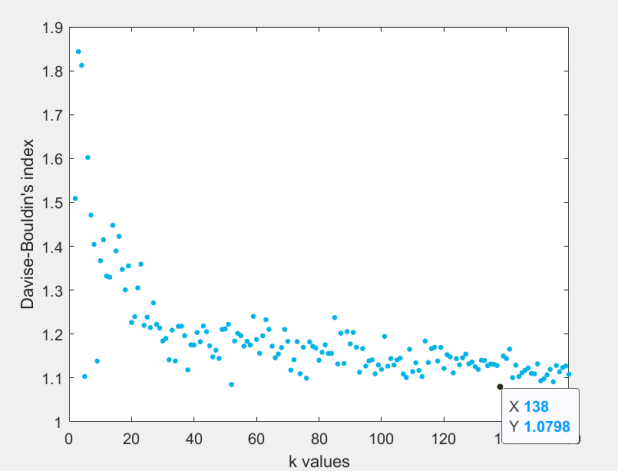
We used Davies-Bouldin's validity index (DBI) for partitioning with different numbers of clusters to choose the best clustering value for K in K-means clustering. Usually, by using DBI we try to reduce the distance within a cluster, and at a same time, we also try to increase the separation between clusters. Based on the proposed centroids, DBI method tries to evaluate clustering outcomes. Figure 1a shows the DBI for up to K=160 in the K-means clustering for the 6417 codebooks (units/cells) in the application of SOM to the data set of CVEs (expressed via NLP-based embedding). Figure 1b shows the Error Sum of Squares for the related codebooks.

To the best of our knowledge, this is the first such study to undertake massive clustering of a large set of vulnerabilities. We therefore hope to provide a novel tool to cyber defenders to enhance both the theory and practice of cyber security.

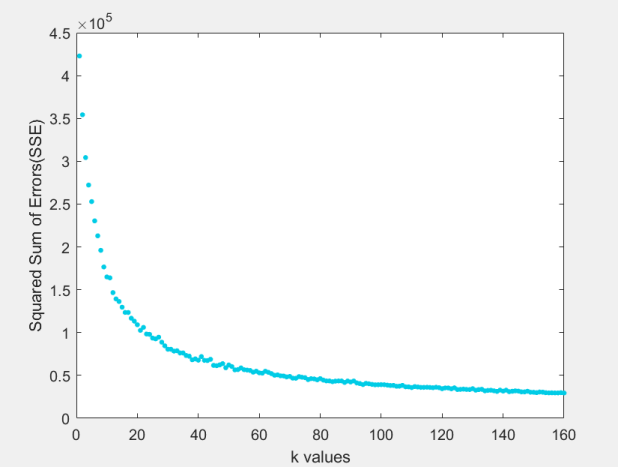
II. Methodology

In this paper, we used the information from the NVD database with all the CVEs from 1999 to 2020, and we processed it with the natural language

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.



(a) K-means clustering using Davise-Bouldin's Index



(b) Squared sum of errors for selecting best value of k

Fig. 1: Davise-Bouldin's Index for K-means clustering using SOM

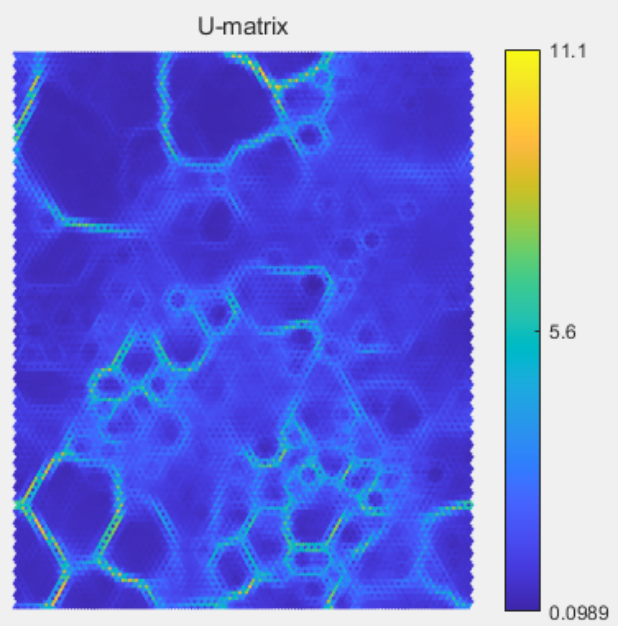
processing model V2W-BERT. Once we receive the processed data from the natural language processing tool, it is converted into a vector format. Then we utilize codebooks generated by the SOM process to perform K-means clustering. We used the tools provided by the SOM toolbox[2] for data compression and visualization. We filtered the original set to get the records with a valid CWE label (99,950 records). The data was read from an ASCII file into a SOM_PAK format, and the data size is 99,950 records with 768 attributes. The map size was selected by using the 'big' option in SOM toolbox. SOM is initialized randomly. The training is performed in two phases: rough training and fine-tuning, which are performed using either sequential or batch modes.

After processing the data, the 99,950 records get compressed into 6417 codebooks, a two-dimensional representation of the input space prototypical vectors mapped to each node of the hexagonal grid, an arrangement of units. Codebooks are expected to be similar to the centroids that would result from K-means applied directly to the input data. Then, we generate Best-Matching-Unit (BMU) in the SOM output array for an input vector. The default output vector is the node of the SOM output array with a codebook that is most similar to the input vector when compared using Euclidian distance between the two vectors. The `som_bmus()` function assigns each 99,950 records to an codebook value from 1 to 6417.

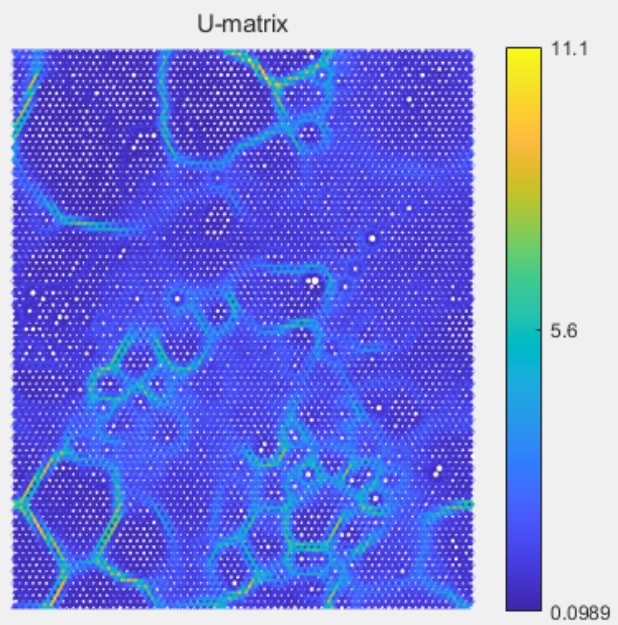
There are multiple techniques to display clusters on SOM. A unified distance matrix, also known as U-matrix is used to visualize the similarity of the codebooks of adjacent nodes by using a different coloring of the connection between nodes. An example of a U-matrix is shown in Figure 2a. The light blue dots indicate the location of map units and hexagons between them show the actual values of the U-matrix. The darker the shade, the smaller the distance. UMAT is related to the difference in codebooks. Similar codebooks (smaller UMAT) make up clusters. In Figure 2b, larger dots show a greater number of hits. Boundaries between clusters are the same as in Figure 2a. Information on 'hits' can be specifically used in SOM clustering by indicating cluster borders with zero-hit units. The hits or size markers represent the distribution of each neuron. We have used `som_show()` function to visualize U-matrix. Using SOM with the K-means algorithm provides accuracy and consistency because it only works with local optimum with random initial center points. We are using `som_kmeans()` to implement k-means algorithm over the codebooks. An example syntax of `som_kmeans()` is: `[codes, clusters, errors] = som_kmeans('batch', sM, k)`, where output arguments are codes that represent codebook vectors, clusters represent cluster numbers related to each cluster, and errors represent total quantization error for the data set. The first input argument is a method that could be

[2]http://www.cis.hut.fi/projects/somtoolbox

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.



(a) U-matrix using SOM



(b) U-matrix with hits

Fig. 2: U-matrix visualisation using SOM

either 'batch' or 'seq'. The second input argument is the data matrix, and the third 'k' is the total number of centroids. Figure 3 represents U-matrix using K-means clustering with 138 clusters where each neuron gets a value between 1 to 138. Colors from blue to yellow represent each cluster group.

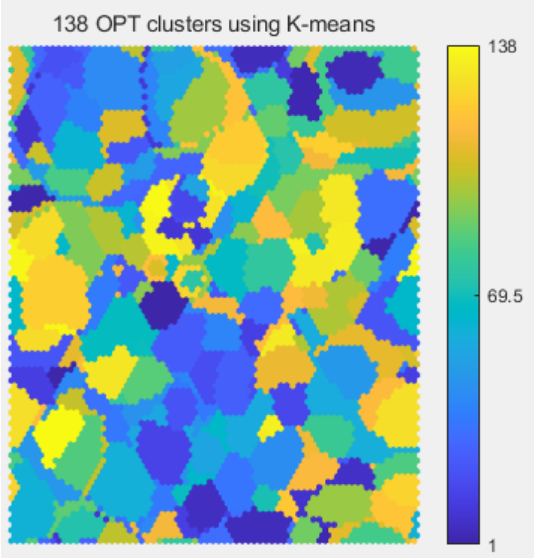


Fig. 3: U-matrix using K-means with 138 clusters

III. Preliminary Results and Analysis

A. Clustering Results

Based on the Davies-Bouldin index, we chose 138 as the best value of K to use in K-means clustering of nodes in the SOM output array. On the basis of their characteristics, CVEs are distributed into multiple clusters based on similarity or dissimilarity (originating from their NLP-based embeddings from V2W-BERT). Figure 4 shows the distribution of CVEs based on CWE labels in the first 10 clusters. X-axis shows the CWE labels that belong to specific cluster and the Y-axis shows the total count of data points that belongs to a particular CWE label. As highlighted for Cluster 5, CWE-416 counts for more than 98% of the data. All other elements are limited in the remaining 2% of the population of the cluster. Similarly in Cluster 6, 94% of population from CVE data points goes to the prominent CWE-59, and all other CWE labels are part of the remaining 6% of the population. From the distribution of counts over CWE label, one can reasonably conclude that association with CWEs 416 and 59 are the primary reasons for CVE membership in clusters 5 and 6, respectively. The secondary peaks, CWE 399 and 264 in clusters 5 and 6 respectively, might play some role in the assignment of CVEs to clusters 5 and 6, but the remaining peaks can be dismissed as random noise from natural language processing

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.

of the text of CVEs. We examine individual BMU clusters in terms of primary, secondary and noise contributions. Cluster 9 has only one label (CWE-79), which demonstrates that there is no noise contribution involved in the distribution of CVEs for this particular cluster.

Figure 5 shows the contributions of CWEs 59 and 246 to the BMUs of the CVEs that are members of cluster 6. The X-axis shows all the BMUs that became members of Cluster 6. The Y-axis shows the proportion of CVEs with labels CWE 59 and 264 that became members of Cluster 6 via the indicated BMU. The ten full blue bars show BMUs CWE 59-labeled CVEs. Similarly, the two full orange bars contain only CWE 264-labeled CVEs. Comparing the text of CVEs in these two groups might reveal aspects captured by natural language processing that distinguish them. Most cells in this region of the SOM output were BMUs for a combination of CWE 59- and 264-labeled CVEs, with a predominance of CWE 59 as revealed by the bar graph of Cluster 6 in Figure 4.

B. Observations and Analysis

Cluster analysis is the process of combining data into subgroups in a way that a particular node is closer to the node with similar characteristics, while dissimilar nodes are outside of the cluster [6]. Since some clusters combined apparently disparate data (for example, Figure 5), the reasoning for why CWE-59 and CWE-264 got included in the same cluster becomes essential to understand. We can observe that both the CWEs are members of CWE-635 and CWE-1345. CWE-1345 comes under the "Broken Access Control" category, which is part of the Open Web Application Security Project (OWASP) – a Top-10 2021 category. To learn structure of each cluster and visualize their distribution on a map, we introduced a U-matrix representation for some of the clusters. It shows the location of a singular cluster on the U-matrix. Such a visual representation can enable the study of adjacent clusters, and the intuitive reasoning behind the juxtaposition of entites (CWEs).

We analyzed all the 138 clusters based on their two prevalent peak percentage values. CWE-79 is the first one in the list of 2020 Top-25 CWEs with a score of 46.82 based on the Common Vulnerability Scoring System (CVSS) score. CWE-79 is described as "Improper neutralization of input during web page generation", which is also considered as cross-site scripting [7]. In Figure 6 we observe all the clusters, such as 9, 24, 27, 38, 42, 49, 61, 73, 83, 102, 104, 108 that have CWE-79 as their dominant peak in the peak percentage table. Together, the entire cluster can be called a supercluster for CWE-79. When we calculated the space between all the adjacent clusters from Cluster 9, it is visible how close they are in the trained map to each other. For example, the distance from the centroid of Cluster 9 to the centroid of Cluster 24 is 2.2365, the distance from Cluster 9 to Cluster 27 is 1.2940, and the distance from Cluster 9 to the adjacent Cluster 61 is 2.0085, etc. Consequently, based on distance measurements, we can conclude that Cluster 27 is relatively closer to Cluster 9.

CVE-Id	**CWE-label**	**Cluster Number**	**BMU-index**
CVE-2002-1852	CWE-79	104	1329
CVE-2002-2422	CWE-79	104	486
CVE-2003-0801	CWE-79	104	1422
CVE-2004-0067	CWE-79	104	1421
CVE-2005-2022	CWE-79	104	1608

TABLE I: A small sample of CVEs in Cluster 104. The CVEs are mapped to CWE-79.

Further, a careful consideration of CVEs in Cluster 104, an adjacent cluster corresponding to other clusters, reveals similarities between Cluster 9 and Cluster 104. The first CVE in Table I is 'CVE-2002-1852' which is described as Cross-site scripting (XSS) vulnerability in an individual app that allows remote attackers to inject arbitrary web script or HTML via either the URL or a parameter used to test. The second CVE shown in the table is 'CVE-2002-2422' which is also a Cross-site scripting (XSS) vulnerability but in various applications that authorizes remote attackers to inject arbitrary web script or HTML via a URL, which inserts the script into the resulting error message. Both of the above-mentioned CVEs are for Cross-site scripting (XSS) vulnerability that inject malicious scripts into

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.

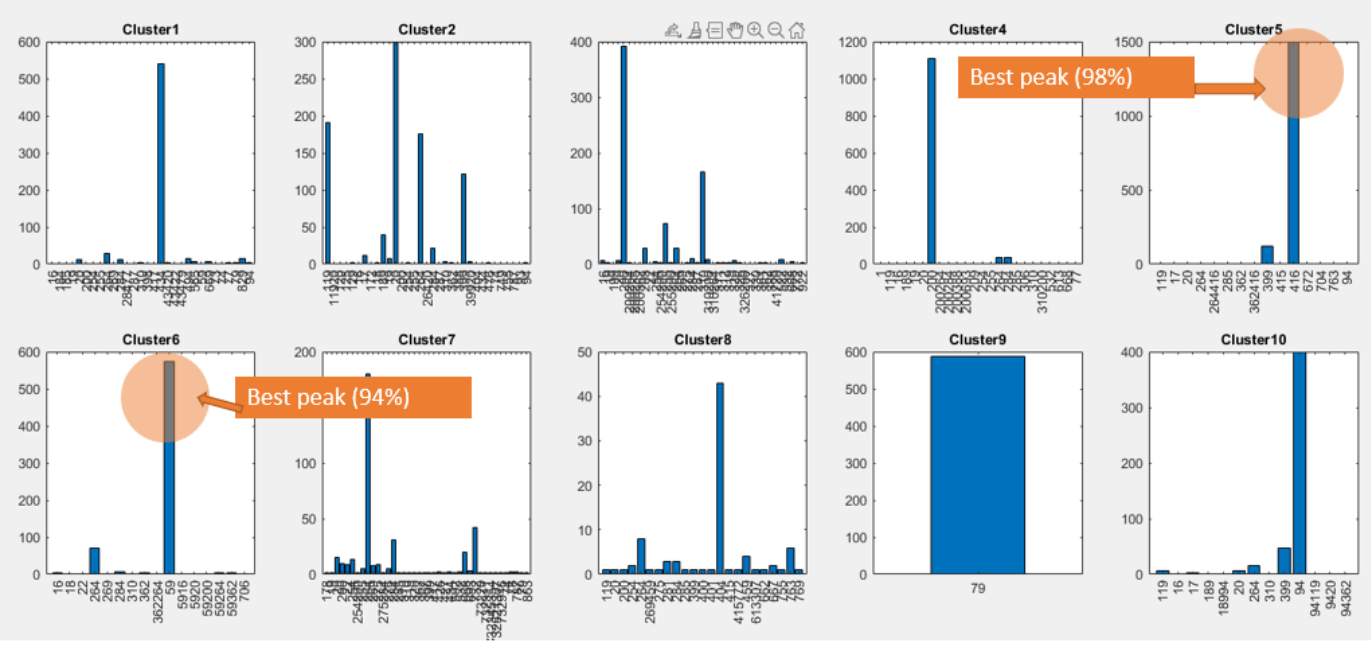


Fig. 4: Bar plots of distribution of CWEs for first 10 clusters. The Y-axis represents the frequency of a given CWE in the cluster, ampped along the X-axis.

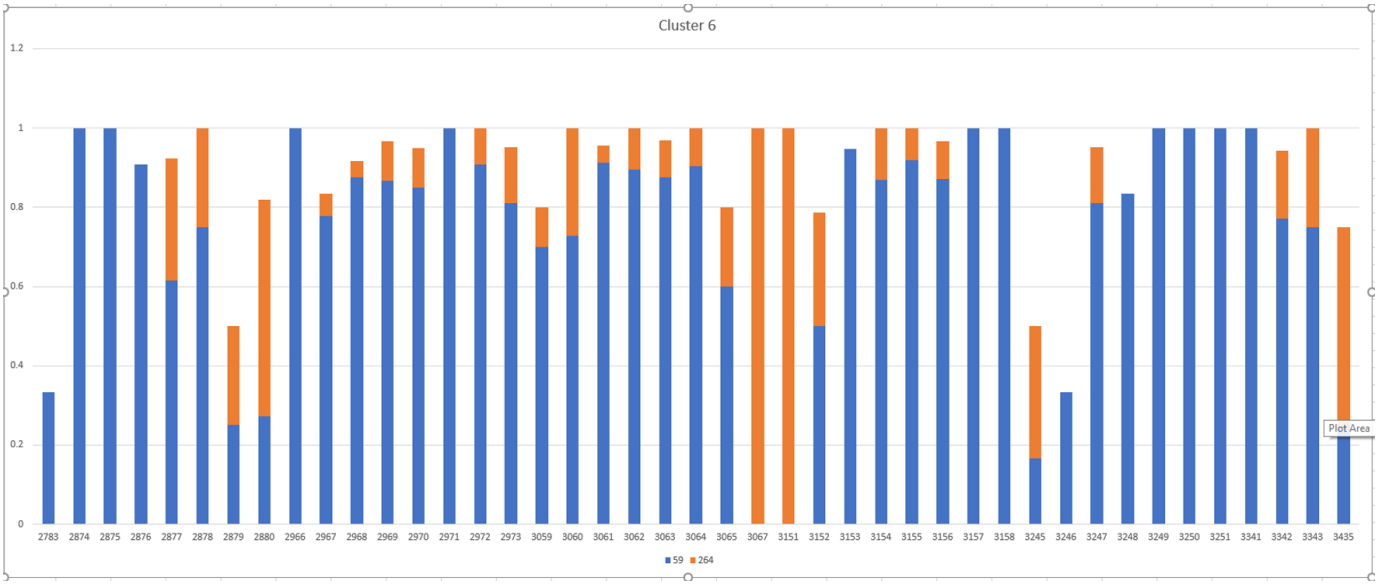


Fig. 5: Role of CWEs 59 (in blue) and 264 (in orange) in the BMUs of Cluster 6. BMUs are plotted along the X-axis, and the Y-axis shows the proportion of CVEs with labels CWE 59 and 264.

applications and violate the privacy and security of web applications. This demonstrates the power of visual analysis of vulnerability information using SOMs, as well as accurate mapping of CVEs to CWEs.

ACKNOWLEDGEMENTS

This work is supported in part by the U.S. Department of Energy (DOE) through the Center for ARtificial Intelligence- focused ARchitectures and Algorithms (ARIAA). We are grateful for access to

978-1-6654-9404-5/22/$31.00 ©2022 IEEE
Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.

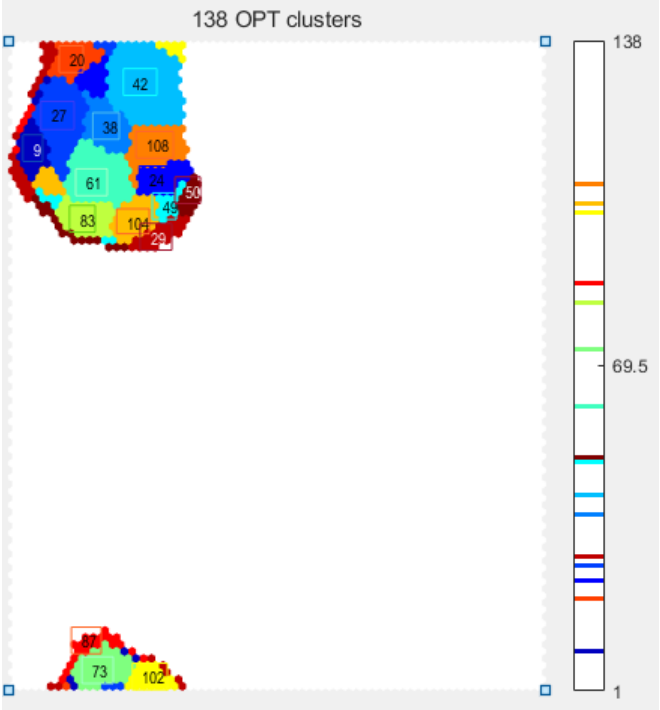


Fig. 6: U-matrix of clusters only containing CWE-79 for prominent peak percentage $\geq 50\%$. Please note that the map is a torus that wraps around from left-to-right and top-to-bottom.

institutional computational resources at PNNL.

REFERENCES

[1] O. Alhazmi, Y. Malaiya, and I. Ray, "Security vulnerabilities in software systems: A quantitative perspective," in *IFIP Annual Conference on Data and Applications Security and Privacy*. Springer, 2005, pp. 281–294.

[2] K. Tasdemir and E. Merényi, "Exploiting data topology in visualization and clustering of self-organizing maps," *IEEE Transactions on Neural Networks*, vol. 20, no. 4, pp. 549–562, 2009.

[3] S. S. Das, E. Serra, M. Halappanavar, A. Pothen, and E. Al-Shaer, "V2w-bert: A framework for effective hierarchical multiclass classification of software vulnerabilities," *arXiv:2102.11498*, 2021.

[4] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, Ł. Kaiser, and I. Polosukhin, "Attention is all you need," in *Advances in Neural Information Processing Systems (NIPS*, 2017, pp. 5998–6008.

[5] D. Chicco, "Siamese neural networks: An overview," *Artificial Neural Networks*, pp. 73–94, 2020.

[6] Y. Dogan, D. Birant, and A. Kut, "Som++: integration of self-organizing map and k-means++ algorithms," in *International Workshop on Machine Learning and Data Mining in Pattern Recognition*. Springer, 2013, pp. 246–259.

[7] A. Honkaranta, T. Leppänen, and A. Costin, "Towards practical cybersecurity mapping of stride and cwe—a multi-perspective approach," in *2021 29th Conference of Open Innovations Association (FRUCT)*. IEEE, 2021, pp. 150–159.

978-1-6654-9404-5/22/$31.00 ©2022 IEEE

Authorized licensed use limited to: Indian Institute Of Technology (Banaras Hindu University) Varanasi. Downloaded on September 08,2026 at 18:54:13 UTC from IEEE Xplore. Restrictions apply.